

Who can see what

Two roles, one API. The dashboard never decides what a user can see — the token does, checked on every request. This is the shape we're committing to before Matt writes the auth middleware.

How the rule gets enforced

01 • LOGIN

User signs in. Issued a token carrying *role* and *home branch*.

02 • REQUEST

Dashboard calls the API with a branch/period query — plus the token in the header.

03 • RULE (§3.2)

API reads the *role* off the token, not the query string, and resolves scope from it.

04 • RESPONSE

Only data inside that scope comes back. The action is written to the audit log.

The two roles

Branch Manager

scope: own branch

TOKEN CARRIES

role = branch_manager, home_branch = e.g. "Florence"

CAN SEE

- Their own branch's KPI cards, cash-flow, loans, expenses, bills of exchange
- Their own branch's alerts, and can acknowledge them
- Their own branch's transaction table (searchable, sortable)

Cannot see other branches or the network view — even if they edit the URL or query string to name a different branch, the API resolves it back to their own.

Managing Director

scope: entire network

TOKEN CARRIES

role = managing_director, home_branch = null

CAN SEE

- Every branch, individually — same KPI/alert/transaction views a manager gets
- The network-wide view: branch comparison, total network results
- Flags on unusual branch performance, with drill-down into any branch

No branch restriction on the token — the branch parameter in a request is honored as given, or omitted entirely for the network rollup.

Endpoint access matrix

ENDPOINT	BRANCH MANAGER	MANAGING DIRECTOR
GET /api/kpis	✓ own branch only	✓ any branch
GET /api/transactions	✓ own branch only	✓ any branch
GET /api/cashflow	✓ own branch only	✓ any branch
GET /api/loans	✓ own branch only	✓ any branch
GET /api/expenses	✓ own branch only	✓ any branch
GET /api/alerts	✓ own branch only	✓ any branch
POST /api/alerts/{id}/acknowledge	✓ own branch's alerts	✓ any branch's alerts
GET /api/network/summary	— not exposed to this role	✓ all branches, aggregated

Why this is decided now, not later

The check lives in one place: the API. Neither dashboard is trusted to hide data on its own — a branch manager's UI could be fully rebuilt and it still couldn't pull another branch's numbers, because the API resolves scope from the token before it ever looks up a KPI Result or Alert Record. Every read and every acknowledgement is written to the audit log with who, what role, and what scope they acted under. Retrofitting this after Matt's API exists means re-checking every endpoint one at a time — deciding the shape now means there's only ever one rule to enforce.